Implementation Defects in HQC's Optimized Decoder: Reproduction, Downstream Exposure, Decryption-Failure Impact, and C2PRI of the v5 Transform

AUTHOR NAME*

Draft of 4 November 2026

Abstract

HQC was selected by NIST in March 2025 as a backup KEM to ML-KEM; its standard (FIPS 207) is not yet final. We audit the official implementation (v5.0.0 and v5.1.0) across 40 builds per parameter set (two code paths, two compilers, five optimization levels), with known-answer tests, Valgrind-based secret tracking, a division-instruction scan and dudect timing. Most defects we find are already tracked upstream; we reproduce them independently and add four results. (i) For the AVX2 Reed–Muller peak-search defect (HQC issue #46), whose effect on the decryption failure rate (DFR) had not been estimated, we combine 1.68×10^9 blocks of simulated real decryption noise with an exact per-weight model. The defect adds about 7.8×10^{-12} block errors per block for HQC-1 ($q/p \approx 8\times10^{-9}$) and essentially none for HQC-3/5, so its DFR impact is negligible. (ii) With crafted ciphertexts that make the reference and AVX2 decoders disagree on up to all 46 blocks, decapsulation outputs remain identical in 6,000 trials. (iii) The known secret-dependent branch in the AVX2 decoder is measurable by dudect ($|t| = 98$ against 6 for the reference decoder), and a known Clang-introduced branch in key sampling runs on the long-term key in every decapsulation. (iv) The KEM transform changed in v5 and is not covered by published C2PRI or binding analyses; we give a classical-ROM proof sketch that it is C2PRI, which would let hybrid combiners omit the HQC ciphertext from key derivation.

1 Introduction

Post-quantum KEMs are being deployed before their implementations have been studied as long as their mathematics. HQC [13] is a code-based KEM whose decryption decodes a concatenated Reed–Solomon/Reed–Muller code under noise; its optimized AVX2 decoder and its sampling code are where implementation choices meet secret data.

The implementation is under active third-party audit. Upstream tracks compiler-induced constant-time issues [5], an alignment problem on Armv7 [6], and two AVX2 decoder defects found with pq-verify [7, 8, 16]. CT-KAT [12] screened ML-KEM, ML-DSA, SLH-DSA and Falcon, but not HQC.

Contributions. We do not claim the discovery of any previously unknown vulnerability. We contribute:

- An independent multi-build reproduction of the AVX2 strict-aliasing miscompilation (§3) and a triage of all Valgrind reports against the known-issue lists (§4).
- A timing measurement of the known AVX2 decoder branch (§5).

*Draft. Tooling and data: `https://github.com/Tarekswd/PHOENIX-PQ`.

- The first estimate of the DFR impact of the #46 peak-search defect, with a validated exact model (§6), and an experiment showing the decoder difference does not reach decapsulation outputs (§7).
- A downstream check of liboqs and PQClean (§8).
- A proof sketch that HQC v5's transform is C2PRI (§9).

2 Setup

Target. The official implementation [4] at v5.0.0 (`f46e542`) and v5.1.0 (`06567cc`), parameter sets HQC-1/3/5. The upstream build is CMake Release (`-O3`).

Build matrix. We build {reference, AVX2} × {GCC 13.3.0, Clang 18.1.3} × {`-O0`, `-O1`, `-O2`, `-O3`, `-Os`}. Other flags mirror upstream (C99; `-mavx -mavx2 -mbmi -mpclmul` and unrolling for AVX2). Every build must reproduce the shipped KAT files.

Platform. Ubuntu 24.04 under WSL2 on an AMD Ryzen 7 PRO 4750U (Zen 2). CPU boost cannot be disabled under WSL2, which limits the timing results.

3 Build correctness

36 of 40 builds per version pass the KATs. The four failures are AVX2 with GCC at `-O2` and `-Os`, in both v5.0.0 and v5.1.0, and for HQC-3/5 as well. With random keys, decapsulation of valid ciphertexts failed in 294 of 300 runs.

Bisection isolates `src/x86_64/avx256/reed_muller.c`. The function `find_peaks` reads an `__m256i` through a `uint16_t*`, which is a strict-aliasing violation. Replacing that read with `memcpy` makes all 40 builds of both versions pass, as does `-fno-strict-aliasing`.

This defect was already reported as HQC #39 and #46 [7, 8]; the same pattern had earlier been fixed in PQClean [15]. Builds at the upstream default `-O3` are unaffected.

4 Secret-dependent control flow

Valgrind memcheck with secrets marked undefined (the ctgrind technique [11]) produced 59 distinct reports for HQC-1. HQC-3/5 add no new locations. Table 1 classifies them.

A scan for `div`/`idiv`, motivated by KyberSlash [10], finds none at `-O1` to `-O3`. At `-O0` and `-Os` it finds divisions only in SHAKE, where both operands are public.

5 Timing of the known decoder branch

We ran a dudect [17] fixed-vs-random Welch test on HQC-1 Reed–Muller decoding at block noise weight 132, with 2×10^6 interleaved measurements on a pinned core. The AVX2 decoder gives $|t|$ up to 98.4: fresh inputs take about 150–240 more cycles (0.5–0.8%). The branch-free reference decoder, used as a control, stays at $|t| \leq 6.4$.

This turns the [5] entry from a tool report into a measured timing dependence. It does not quantify what an attacker learns from it.

Location	Builds	Assessment
`vect_generate_random_support1`	all	Variable-time rejection sampling by design: the iteration count depends on rejected candidates only.
`find_peaks` (AVX2)	`-O3`, both compilers	Real branch on secret peak comparisons (`vptest; sete; jne`). Known: [5], "Reed-Muller".
`compute_error_values`	v5.0.0, Clang	Gone in v5.1.0 after the RS rewrite, as upstream planned.
`vect_write_support_to_vector`	ref, Clang `-O1`–`-O3`, `-Os`	Clang turns the mask `1^((t|-t)>>31)` into `cmp; je` on (loop word = secret support word) while sampling x, y. These are re-derived in every decapsulation, so the branch reveals the 64-bit word of each secret position. Already suppressed in liboqs's constant-time tests; not in [5].
`gf_mul`	ref, Clang `-O1`	Branch on field-element bits; not a documented build.

Table 1: Triage of Valgrind reports (HQC v5.1.0).

6 DFR impact of the peak-search defect

Defect. The AVX2 decoder's peak search starts at width $2^{5+\lfloor M/2 \rfloor}$, which is 64 for HQC-1 ($M = 3$) and 128 for HQC-3/5 ($M = 5$). When two Hadamard values exceed this cap, the decoder returns the lower-indexed one instead of the larger [8, 16]. Both sources note that its DFR effect was not estimated.

Simulation. We generate the decoder input exactly as in `hqc_pke_decrypt`: $\text{encode}(m) + \text{Truncate}(xr_2 + r_1y + e)$, with sparse products in $\mathbb{F}_2[X]/(X^n - 1)$. Each block is decoded by three decoders linked side by side:

- the reference decoder (exact maximum likelihood);
- the official AVX2 decoder;
- AVX2 with the #46 width fix.

A positive control builds blocks $N_2/4 - 1$ flips from the sent codeword and $N_2/4 + 1$ from a competitor. On these the official AVX2 decoder returns the farther codeword in about 50% of 57,396 blocks, while the other two decoders are always correct.

Exact model. For noise of weight w placed uniformly in a block, the true peak is $N_2/2 - w$. Each of the 127 competitors is $|2k - w|$ with $k \sim \text{Hypergeometric}(N_2, N_2/2, w)$. The defect requires $\text{cap} < |2k - w| < N_2/2 - w$ together with a lower index; we take a union bound over competitors and weight ties 1/2. The model matches simulation where probabilities are small: for HQC-1 at $w = 150$ it gives 1.436×10^{-3}, against 1.440×10^{-3} for uniform noise and 1.460×10^{-3} for real HQC noise. Real HQC noise thus behaves like uniform noise given its weight.

Why it is negligible. The defect needs a *light* block, $w < N_2/2 - \text{cap}$, plus a second codeword above the cap: a 7-sigma event at those weights. Decryption failures come from heavy blocks. For HQC-1 the defect probability peaks at $w = 125$ at 6.8×10^{-11}, while reference errors begin around $w = 139$.

Under an independent-block binomial model with $\delta = (n_1 - k)/2$, the relative DFR increase is about 1.3×10^{-7} for HQC-1 and zero to double precision for HQC-3/5. A further 4.9×10^{8}

	HQC-1	HQC-3	HQC-5
Real-noise blocks simulated	8.84×10^8	4.03×10^8	3.92×10^8
Reference block error rate p	9.43×10^{-4}	6.97×10^{-5}	5.20×10^{-4}
Defect-only errors observed	0	0	0
95% upper bound on q	3.4×10^{-9}	7.5×10^{-9}	7.7×10^{-9}
Model q	7.8×10^{-12}	7.6×10^{-33}	7.3×10^{-34}
Mean block weight	132.5	232.7	240.0

Table 2: Peak-search defect under HQC decryption noise (v5.1.0).

blocks drawn with HQC's own sampler for r_1, r_2, e reproduce these rates within statistical error. The width fix agreed with the reference decoder on every block we simulated.

7 Crafted ciphertexts

Knowing y, we construct ciphertexts with $v = \text{Truncate}(uy) + R$, where R makes the two decoders disagree on 11 to 46 of HQC-1's 46 blocks. We decapsulate them with a reference build and with a build in which only the RM decoder is replaced by the AVX2 one. Over 5,000 crafted, 500 honest and 500 random ciphertexts, the shared secrets were identical in every case, and all honest ciphertexts decapsulated correctly.

This is what the transform predicts. A ciphertext that is not an honest encryption of the decoded message fails re-encryption in both builds and receives $\bar{K} = J(H(ek), \sigma, c)$, which does not depend on the decoded message. Meanwhile, honest ciphertexts' noise is fixed by G and by the secret key, so it cannot be steered into the region where the decoders disagree. The defect therefore affects only the honest DFR of §6.

8 Downstream libraries

- Neither liboqs [14] nor PQClean ships HQC's AVX2 code, so neither carries the #39/#46 defects.
- liboqs imports HQC commit `161cd4f`, the commit cited in [6], and keeps the `uint8_t→uint64_t*` casts. liboqs lists ARM32v7 as a supported target.
- Cross-built for ARMv7 and run under QEMU user mode, liboqs's HQC KEM tests pass for all three parameter sets. QEMU may not model alignment traps, so real hardware is still needed.

9 C2PRI of the HQC v5 transform

The gap. ABK25 [1] prove C2PRI for the $U^{\perp}$, $U^{\not\perp}$, $U_m^{\perp}$ and $U_m^{\not\perp}$ transforms. Their HQC theorem models the 2024 specification, in which $K = H(m, u, v)$ and the salt is not bound; KSW [9] analyse round-4 HQC.

The v5 transform. Since v5.0.0 (specification of 2025-08-22 [3]), HQC derives

$$(K \| \theta) = G(H(ek) \| m \| salt), \qquad c = (\text{Enc}(ek, m; \theta), salt),$$

and rejects with $\bar{K} = J(H(ek) \| \sigma \| u \| v \| salt)$, where G is SHA3-512, J is SHA3-256, both domain-separated, and $|K| = 256$ bits. This structure resembles ML-KEM's. To our knowledge no published analysis covers it.

Claim (sketch, classical ROM). Model G_1 (the K part of G) and J as independent random oracles. An adversary that is given (ek, dk, c, K) and makes q_G, q_J queries outputs $c^* \neq c$ with $\text{Decaps}(dk, c^*) = K$ with probability at most

$$\frac{(q_G + 2)^2 + (q_J + 2)^2}{2^{257}} + \frac{q_G + q_J + 2}{2^{256}}.$$

Proof sketch. There are four cases:

- Both c and c^* pass re-encryption. Then $(m^*, salt^*) \neq (m, salt)$, since otherwise $\theta^* = \theta$ forces $c^* = c$. So the adversary has found a G_1 collision.
- Exactly one of them passes. Then an output of one oracle must equal a fixed output of the other.
- Both fail. Then J collides on distinct inputs, because J hashes all of $(u, v, salt)$.

The argument does not need c to decrypt correctly.

Consequence. If the claim holds, ABK25's Theorem 8 lets split-key-PRF hybrid combiners omit the HQC ciphertext from key derivation, as X-Wing [2] does for ML-KEM. For HQC-1 that is 4,433 bytes per handshake. A QROM proof, along the lines of ABK25's O2H-based argument, remains open.

10 Limitations

- One x86-64 microarchitecture, under WSL2. Timing results show input dependence, not attack cost.
- Valgrind observes only executed paths, and our division scan covers only `div`/`idiv`.
- The DFR mapping assumes independent blocks; we report only relative changes, never an absolute DFR.
- The crafted-ciphertext experiment covers HQC-1.
- The C2PRI argument is a sketch in the classical ROM. We checked it against the code, not against the specification text.

11 Conclusion

HQC's optimized decoder had real defects, but they were already being found and fixed upstream. For the one defect whose consequence was open, the answer is reassuring: its effect on the decryption failure rate is negligible, and it does not reach decapsulation outputs. The v5 transform appears to be C2PRI under the same reasoning as ML-KEM, which matters for hybrid deployments. A formal (Q)ROM treatment of that claim is the most useful next step.

References

[1] Gorjan Alagic, Fahran Bajaj, and Aybars Kocoglu. The best of both KEMs: Securely combining KEMs in post-quantum hybrid schemes. Cryptology ePrint Archive, Paper 2025/1444, 2025.

[2] Manuel Barbosa, Deirdre Connolly, João Diogo Duarte, Aaron Kaiser, Peter Schwabe, Karolin Varner, and Bas Westerbaan. X-Wing: The hybrid KEM you've been looking for. IACR Communications in Cryptology 1; ePrint 2024/039, 2024.

[3] HQC team. Hamming quasi-cyclic (HQC), specification of 2025-08-22.

[4] HQC team. HQC official implementation, tags v5.0.0 (f46e542) and v5.1.0 (06567cc).

[5] HQC team. Work item #11: Fix compiler induced constant time issues.

[6] HQC issue #31: kem.c casts uint8_t arrays to uint64_t *, which faults on Armv7.

[7] HQC issue #39: Fix AVX2 RM decoder aliasing bug at -O2.

[8] HQC issue #46: Fix AVX2 Reed-Muller decoding, find_peaks (reported by N. C. Maino).

[9] Juliane Krämer, Patrick Struck, and Maximiliane Weishäupl. Binding security of implicitly-rejecting KEMs and application to BIKE and HQC. Cryptology ePrint Archive, Paper 2024/1233 (IACR CiC 2025), 2024.

[10] KyberSlash: Exploiting secret-dependent division timings in Kyber implementations. IACR Transactions on Cryptographic Hardware and Embedded Systems.

[11] Adam Langley. ImperialViolet: Checking that functions are constant time with Valgrind, 2010.

[12] Seung-Won Lee, Min-Seo Kim, Su-Min Jeong, and Hwa-Jeong Seo. CT-KAT: Beyond pass/fail in constant-time screening of PQC implementations. *Electronics*, 15(21):5068, 2026.

[13] National Institute of Standards and Technology. NIST selects HQC as fifth algorithm for post-quantum encryption, 2025.

[14] Open Quantum Safe. liboqs, commit 8adabb7.

[15] PQClean issue #453: hqc-rmrs-128/avx2/reed_muller.c violating C aliasing rules.

[16] pq-verify, HQC decoder audit (AUDITS.md).

[17] Oscar Reparaz, Josep Balasch, and Ingrid Verbauwhede. Dude, is my code constant time? In *Design, Automation and Test in Europe (DATE)*, pages 1697–1702, 2017.